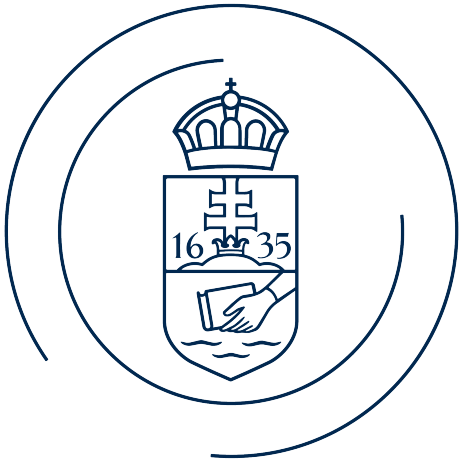


ELTE
EÖTVÖS LORÁND
UNIVERSITY

10101101001010101011101011010010101010111011101011010010101010100

Cybersecurity Basics

Social Engineering
The Human Factor in Cybersecurity Threats

Social Engineering

What you will learn...



- What is Social Engineering, and why is it a major threat?
- What are the most common techniques used in Social Engineering attacks?
- How do attackers exploit human behavior and trust?
- What is phishing, and how can it be detected and prevented?
- How can organizations train employees to recognize Social Engineering tactics?
- What are the key steps to mitigate Social Engineering risks in an organization?
- What role does technology play in preventing Social Engineering attacks?

Social Engineering

What is Social Engineering?



Social Engineering is the practice of **manipulating individuals to gain unauthorized access to systems, data, or resources** by exploiting human psychology rather than technical vulnerabilities. It involves tactics such as deception, impersonation, and psychological manipulation to trick individuals into divulging sensitive information, such as passwords, financial details, or personal data. Social Engineering **aims to bypass technical safeguards by targeting the human element**, making awareness and training critical components of defense.

Key Psychological Triggers in Social Engineering I

- **Curiosity:** Victims are enticed by something intriguing (e.g., "Confidential Document" or "Exclusive Offer"). Attackers exploit human nature's desire to explore unknown or restricted information.
- **Sense of Urgency:** Attackers create pressure, making victims act quickly without thinking (e.g., "Your account will be locked in 24 hours!"). Urgency overrides rational decision-making, leading to impulsive actions.
- **Fear and Anxiety:** Victims react out of anxiety or concern (e.g., fake security alerts, IRS scams, legal threats). Fear-based tactics push individuals to comply out of self-preservation.
- **Trust and Authority:** Messages appear to come from a trusted source (e.g., CEO fraud, IT support scams, government impersonation). Victims are more likely to comply with requests from perceived authority figures.
- **Greed and Reward:** Offers of prizes, discounts, or financial gain trick victims into clicking malicious links. The promise of easy benefits leads to reduced skepticism.

Key Psychological Triggers in Social Engineering II

- **Reciprocity:** Attackers offer something valuable (e.g., free software, exclusive access) in exchange for a small action (e.g., clicking a link or entering login credentials). People feel compelled to return favors, even in deceptive situations.
- **Scarcity and Exclusivity:** Victims are led to believe that an opportunity is limited (e.g., "Only 5 spots left!" or "Limited-time access to classified data"). Scarcity creates urgency and emotional impulsivity.
- **Social Proof and Herd Mentality:** Attackers claim that "many others" have taken the same action, making victims feel safe in following along (e.g., "Thousands of users trust this service!"). People tend to follow crowd behavior, even if it leads to risk.
- **Overload and Fatigue:** Attackers bombard victims with excessive information or repetitive messages (e.g., spam emails, fake customer support calls). Decision fatigue weakens skepticism and leads to compliance.
- **Empathy and Helpfulness:** Attackers play on kindness and willingness to help others (e.g., "I lost my access, can you share the document?"). Exploiting human compassion increases the chances of manipulation.

Major Types of Social Engineering



Phishing

Phishing is among the most common types of social engineering attacks.

What is Phishing?



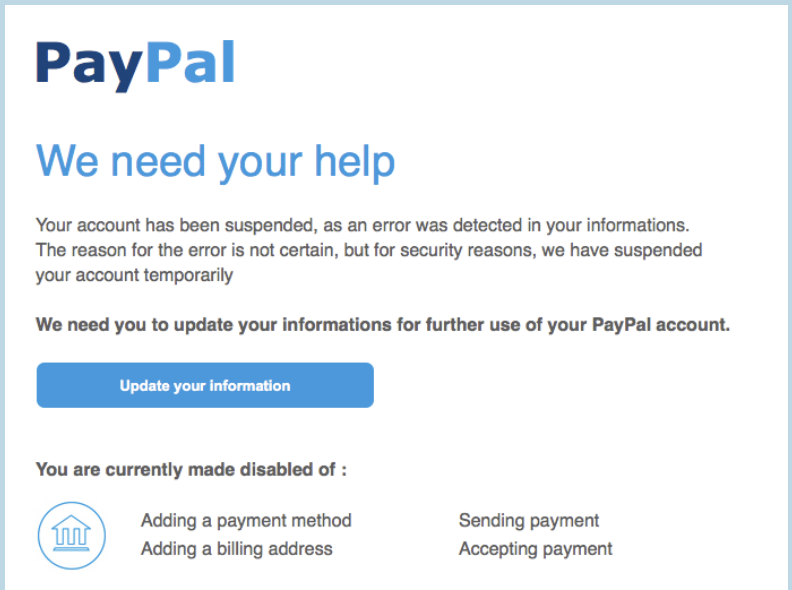
Phishing is a type of **social engineering attack that uses fraudulent communication**—such as **emails**, messages, or **websites**—to trick individuals into providing sensitive information or performing actions that compromise security. These attacks often mimic legitimate entities, such as banks or trusted companies, to gain the victim's trust. **Phishing aims to steal information**, such as **login credentials**, **credit card details**, or other personal data, and may also deploy malware to further compromise systems. A more targeted version of the attack is called spear-phishing.

Sophisticated Phishing e-mail examples

One of the most common examples of phishing originates from emails that appear to be innocent and trustworthy.

- The email uses proper English, with no typos or grammatical errors.
- The sender's email address is spoofed to appear legitimate and familiar.
- Appropriate logos and design elements are included to make the email more convincing.

Phishing E-mail PayPal


PayPal

We need your help

Your account has been suspended, as an error was detected in your informations. The reason for the error is not certain, but for security reasons, we have suspended your account temporarily

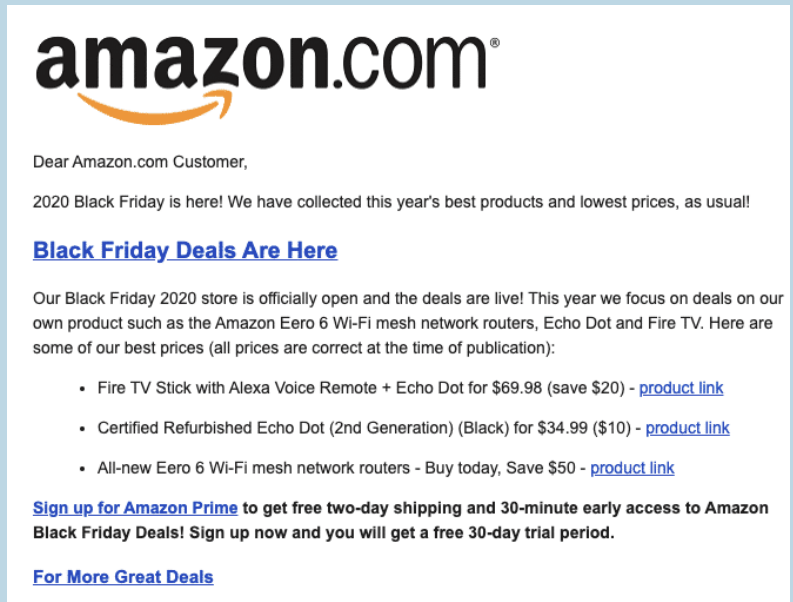
We need you to update your informations for further use of your PayPal account.

Update your information

You are currently made disabled of :

Adding a payment method
Adding a billing address
Sending payment
Accepting payment

Phishing E-mail Amazon


amazon.com

Dear Amazon.com Customer,

2020 Black Friday is here! We have collected this year's best products and lowest prices, as usual!

Black Friday Deals Are Here

Our Black Friday 2020 store is officially open and the deals are live! This year we focus on deals on our own product such as the Amazon Eero 6 Wi-Fi mesh network routers, Echo Dot and Fire TV. Here are some of our best prices (all prices are correct at the time of publication):

- Fire TV Stick with Alexa Voice Remote + Echo Dot for $69.98 (save $20) - product link
- Certified Refurbished Echo Dot (2nd Generation) (Black) for $34.99 ($10) - product link
- All-new Eero 6 Wi-Fi mesh network routers - Buy today, Save $50 - product link

Sign up for Amazon Prime to get free two-day shipping and 30-minute early access to Amazon Black Friday Deals! Sign up now and you will get a free 30-day trial period.

For More Great Deals

Sophisticated phishing email written by GPT-4o

Subject: Urgent: Confidential Transaction Approval

Dear John,

I hope this email finds you well. I am reaching out regarding an urgent and time-sensitive matter that requires your direct attention. We are conducting a confidential executive review to finalize strategic decisions for Q2, and your input is crucial. Given your expertise and leadership, we need your brief confirmation on a key financial directive before it moves forward.

To maintain compliance and security protocols, please review the attached summary and provide your response by 03/27. This document has been restricted to executive-level access only, and your confirmation is required before proceeding to the board.

Your insights will be invaluable, and we appreciate your discretion on this matter. If you have any questions, I am available for a quick call at your earliest convenience.

Please confirm receipt and your availability.

Best regards,

Bertalan

Can we trust in HTTPS? - Types of SSL/TLS Certificates

Domain Validation (DV)

Domain Validation (DV): The most basic type of SSL certificate, DV certificates confirm that the applicant owns the domain but do not verify the organization's identity. They are quick to issue (usually few minutes) and are commonly used for personal or small business websites.

Organization Validation (OV)

Organization Validation (OV): OV certificates require additional verification of the organization behind the domain. They provide a moderate level of trust and are typically used for business websites that collect user data.

Extended Validation (EV)

Extended Validation (EV): EV certificates involve the most rigorous validation process, confirming the organization's legal, operational, and physical existence.

Do you remember green bars?

No More Green Bar for EV Certs



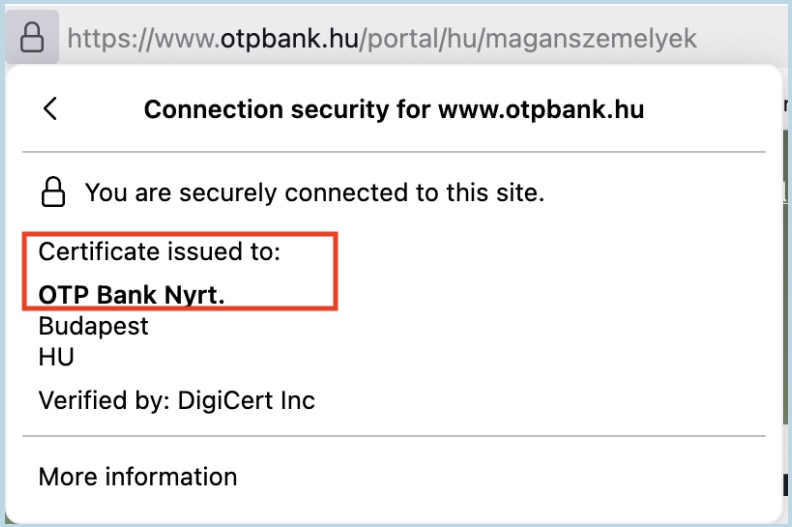
NOTE: Moore info can be found here: `https://www.ssldragon.com/blog/green-bar-ssl/`

EV certs - more trust!

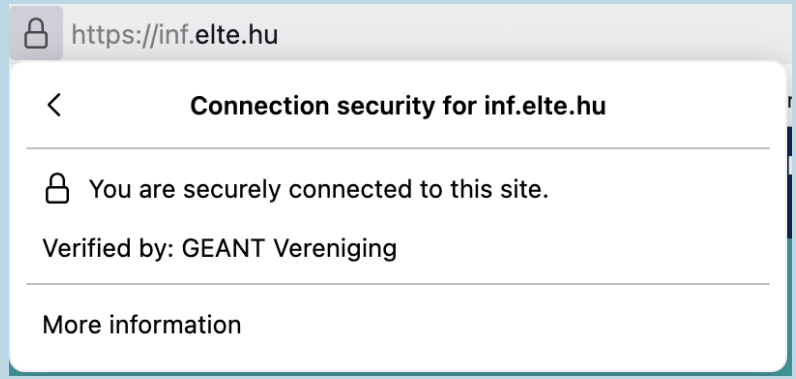
How to Check an Extended Validation (EV) Certificate

- Click the padlock icon in the browser's address bar.
- View certificate details to check the **organization's legal name**.
- Look for an **Extended Validation (EV) indicator** in certificate properties.
- Use online tools like `https://www.ssllabs.com/ssltest/` to verify the certificate type.

EV Cert - otpbank.hu



Non-EV Cert -inf.elte.hu



Easy to create HTTPS? -Let's Encrypt CA Authority



Let's Encrypt is a **free, automated, and open certificate authority (CA)** run for the public's benefit. It provides a straightforward way to secure websites using trusted SSL/TLS certificates.

Definition: Let's Encrypt

Key principles behind Let's Encrypt:

- **Free:** Anyone who owns a domain name can use Let's Encrypt to obtain a trusted certificate at **zero cost**.
- **Automatic:** Software running on a web server can interact with Let's Encrypt to **painlessly obtain a certificate**, **securely configure it**, and **automatically handle renewals**.
- **Secure:** Let's Encrypt serves as a platform for **advancing TLS security best practices**, both by enhancing the CA itself and by assisting site operators in properly securing their servers.

Be cautious of misleading domains and subdomains

A website having a valid HTTPS certificate and proper TLS configuration does not necessarily mean it is a secure website.

- With Let's Encrypt, obtaining an HTTPS certificate is simple;
- Appropriate logos and design elements are included to make the website more convincing.
- The website domain may appear legitimate and convincing.

Valid domains

`https://myaccount.microsoft.com/`
`https://login.ibm.com/`
`https://internetbank.otpbank.hu/`
`https://inf.elte.hu`
`https://neptun.elte.hu`
`https://accounts.google.com`

Phishing domains

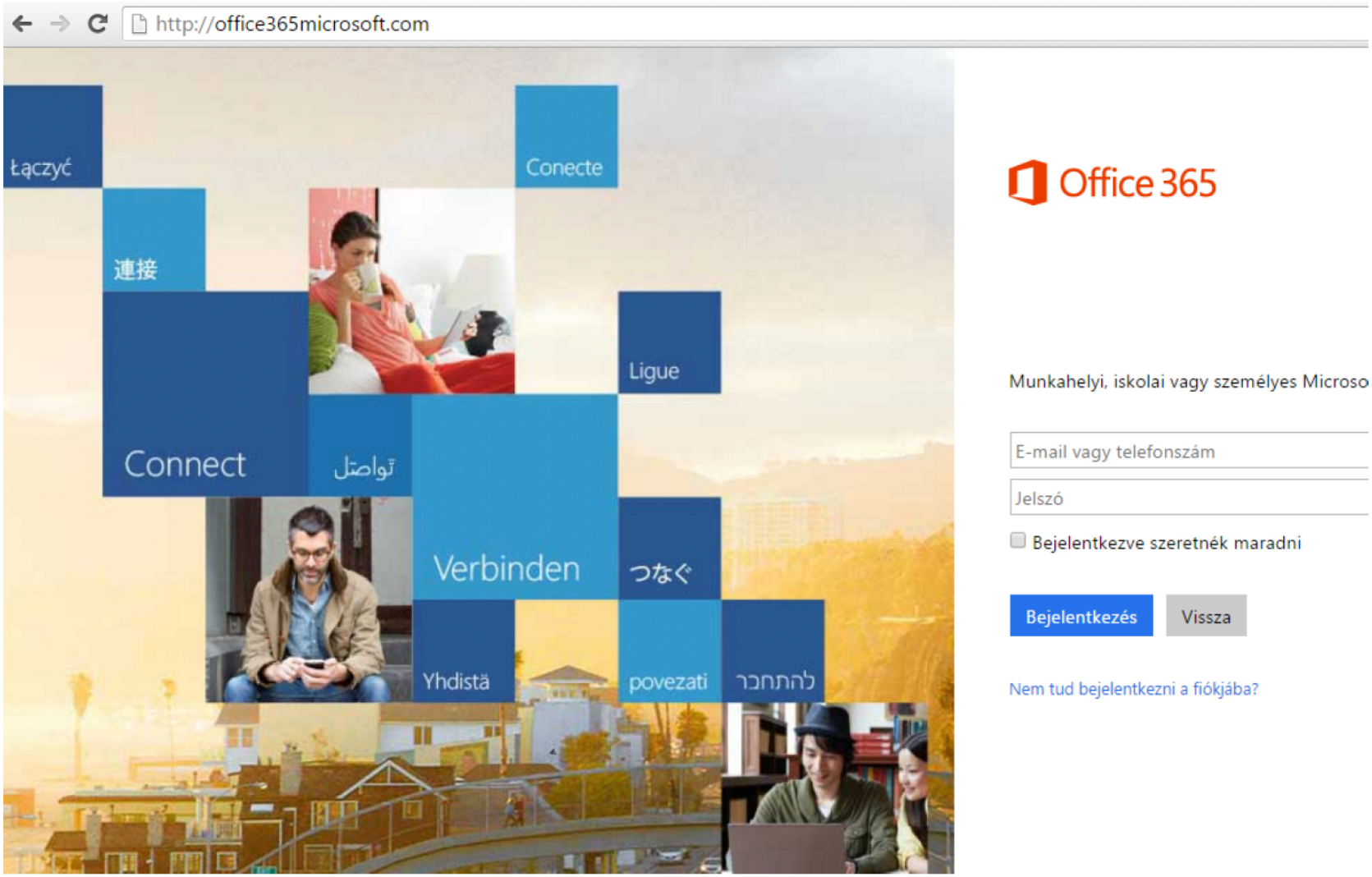
`https://microsoft.secure-login.hu/`
`https://elte.support-security.com/`
`https://appleid.verification-center.net/`
`https://paypal.account-update.info/`
`https://google.login-authenticate.co/`
`https://bankofamerica.secure-payments.cc/`
`https://amazon.verify-account.xyz/`

NOTE: Be mindful of identifying the main domain versus the subdomain. For example, `microsoft.secure-login.com` does not belong to Microsoft! Instead, we own `secure-login.com`, which we purchased for just $8.99 USD.

More examples using typos, misleading subdomain

Domain	Type
https://accounts.google.com/	Valid Domain
https://www.paypal.com/	Valid Domain
https://login.apple.com/	Valid Domain
https://secure.bankofamerica.com/	Valid Domain
https://signin.ebay.com/	Valid Domain
https://icloud.com/	Valid Domain
https://www.microsoft.com/	Valid Domain
https://support.apple.com/	Valid Domain
https://help.instagram.com/	Valid Domain
https://google-secure-login.com/	Suspicious Domain
https://paypa1-security-verification.com/	Suspicious Domain
https://appleid-reset-login.net/	Suspicious Domain
https://bofa-secure-authenticate.com/	Suspicious Domain
https://ebay-account-verification.com/	Suspicious Domain
https://login.raiffesiseen-bank.com/	Suspicious Domain
https://login.microsoft-windows-update.com	Suspicious Domain
https://office365-verify.com/	Suspicious Domain
https://instagram-help-center.net/	Suspicious Domain

Phishing website created by us!



RSA - Fraudulent site - please shut down![Microsoft Office E2127410] 198.199.76.26

"RSA, The Security Division of EMC ("RSA"), an information security company, has been appointed to assist Microsoft Office in preventing or terminating online activity that targets, or may target Microsoft Office's clients as potential fraud victims.

RSA has been made aware that your company appears to be providing internet services to a website, which is making unauthorized use of Microsoft Office's trademarks. This site http://office365microsoft.com not only violates Microsoft Office's copyright, trademarks and other intellectual property rights, but may also become a host to a phishing attack, or other fraudulent scams directed against Microsoft Office and Microsoft Office's clients. "

Whaling

Whaling: A Targeted Form of Phishing

What is Whaling?



Whaling is a **highly targeted phishing attack** aimed at **executives, senior employees, or high-profile individuals** within an organization. Unlike standard phishing, whaling attacks often use **personalized messages** that appear legitimate and urgent.

Common characteristics of whaling attacks:

- **Impersonation** of a CEO, CFO, or senior executive.
- **Highly personalized** emails with insider details.
- **Requests for wire transfers**, sensitive data, or login credentials.
- **Spoofed domains** that closely resemble legitimate ones.

Whaling exploits authority and urgency to manipulate victims into making costly mistakes.

Tailgating / Piggybacking

Tailgating and Piggybacking: Unauthorized Access Tactics

What is Tailgating/Piggybacking?



Tailgating and Piggybacking is a **physical security breach** where an unauthorized person **gains access to a restricted area** by following an authorized individual. **Tailgating relies on human behavior**, such as politeness or distractions, to bypass security measures like keycards or biometric authentication.

Tailgating can lead to serious security risks, such as:

- Unauthorized access to company systems and sensitive data.
- Installation of malicious devices (e.g., USB keyloggers).
- Theft of physical assets or intellectual property.

Tailgating vs. Piggybacking: Unauthorized Physical Access

Tailgating and piggybacking are common **physical security threats** that allow unauthorized individuals to gain access to restricted areas.

- **Tailgating** occurs when an unauthorized person **follows closely behind** an authorized individual without their knowledge.
- **Piggybacking** happens when an authorized individual **knowingly allows** another person to enter without proper authentication.
- These techniques **exploit human trust and courtesy** to bypass security controls.

Tailgating



Example: An attacker **closely follows** an authorized employee into a secure area, **without their knowledge**.

Piggybacking



Example: An unauthorized person **asks an employee** to hold the door open, often pretending to be a visitor, **gaining access intentionally**.

Baiting

Baiting: A Deceptive Social Engineering Attack

What is Baiting?



Baiting is a **social engineering attack** that lures victims into **compromising security by appealing to curiosity, greed, or fear**. It often involves **physical or digital bait** that tricks users into interacting with malicious content.

Common forms of baiting include:

- **Infected USB drives** left in public places (e.g., parking lots, offices).
- **Fake software downloads** that appear as free or premium applications.
- **Malicious ads** (Malvertising) promising rewards or urgent updates.

Baiting preys on human curiosity and can lead to malware infections, data breaches, or credential theft.

Baiting: Luring Victims into a Trap

Baiting is a form of **social engineering attack** that preys on human curiosity or greed to trick individuals into compromising security.

- **Baiting** involves offering a tempting item (e.g., a free USB drive, fake software, or a malicious download) to lure victims into executing malware or exposing sensitive information.
- Attackers exploit **psychological manipulation** to encourage victims to take action.
- Can occur in both **physical** (e.g., infected USB drives) and **digital** (e.g., fake download links) environments.

Physical Baiting



Example: A malicious USB drive labeled **"Confidential Salary Data"** is left in a public area, tricking employees into plugging it into company computers.

Digital Baiting



Example: A fake pop-up offers a **"free software download"**, but instead installs malware.

Pretexting

Pretexting: Manipulating Trust to Gain Information

What is Pretexting?



Pretexting is a **social engineering technique** where attackers create a **fabricated scenario (pretext)** to manipulate victims into **disclosing sensitive information or performing actions**. Unlike phishing, pretexting relies heavily on **building trust and credibility** rather than deception through fake emails or websites. **Common characteristics of pretexting attacks:**

- **Impersonation** of trusted individuals (e.g., IT support, bank representatives, executives).
- **Fake verification calls** asking for account credentials or company details.
- **Personalized scenarios** based on background research (e.g., social media profiling).

Pretexting exploits trust and authority to extract valuable information or gain unauthorized access.

ClickFix attacks

ClickFix: A recently popular social engineering technique

- A website displays a convincing but fake technical error.
- It provides a "Fix" button that, when clicked, automatically copies a malicious PowerShell or terminal command to your clipboard.
- The victim is then instructed to paste and run that command in their system terminal, which bypasses browser security and installs malware directly onto the device.

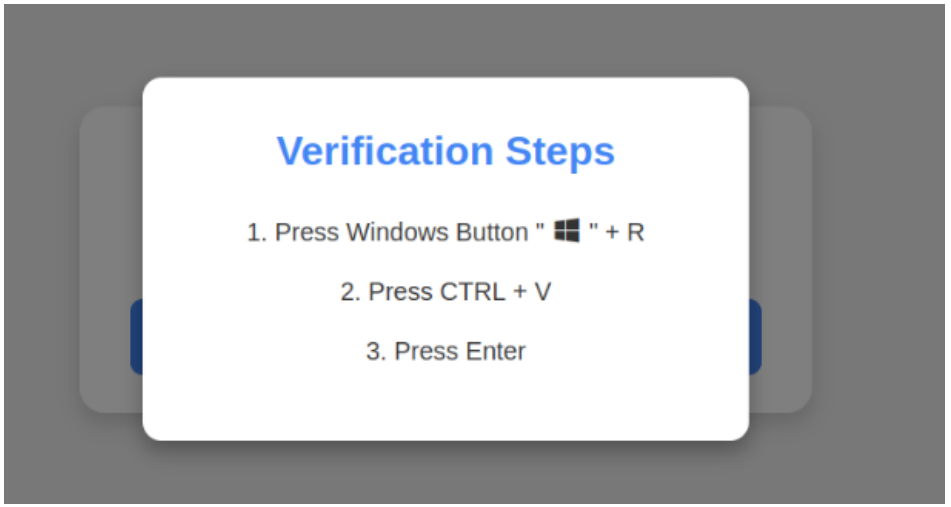


Figure: ClickFix example